UNIT 5

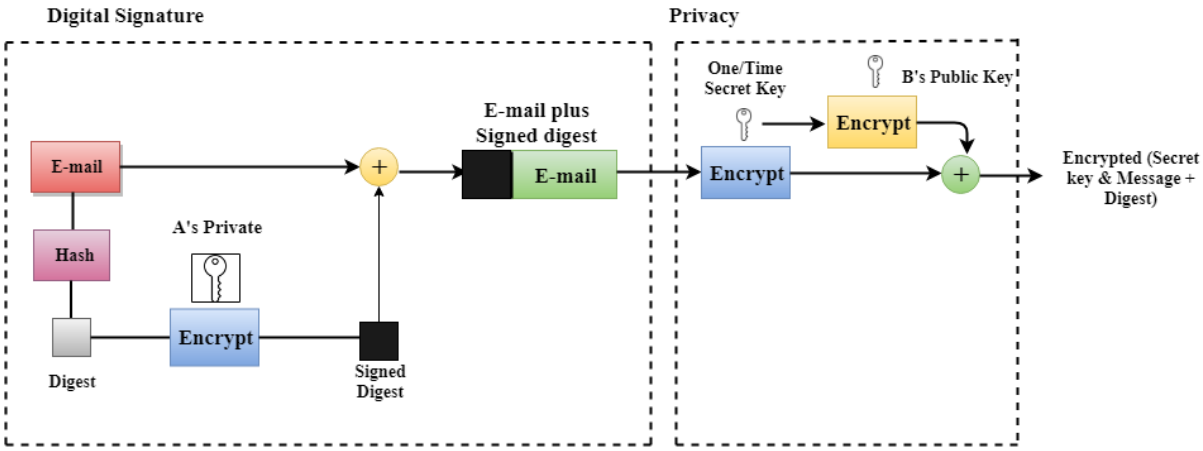
Electronic Mail Security: Pretty Good Privacy

- PGP stands for Pretty Good Privacy (PGP) which is invented by Phil Zimmermann.
- PGP was designed to provide all four aspects of security, i.e., privacy, integrity, authentication, and non-repudiation in the sending of email.
- PGP uses a digital signature (a combination of hashing and public key encryption) to provide integrity, authentication, and non-repudiation. PGP uses a combination of secret key encryption and public key encryption to provide privacy. Therefore, we can say that the digital signature uses one hash function, one secret key, and two private-public key pairs.
- PGP is an open source and freely available software package for email security.
- PGP provides authentication through the use of Digital Signature.
- It provides confidentiality through the use of symmetric block encryption.
- It provides compression by using the ZIP algorithm, and EMAIL compatibility using the radix-64 encoding scheme.

Following are the steps taken by PGP to create secure e-mail at the sender site:

- The e-mail message is hashed by using a hashing function to create a digest.
- The digest is then encrypted to form a signed digest by using the sender's private key, and then signed digest is added to the original email message.
- The original message and signed digest are encrypted by using a one-time secret key created by the sender.
- The secret key is encrypted by using a receiver's public key.
- Both the encrypted secret key and the encrypted combination of message and digest are sent together.

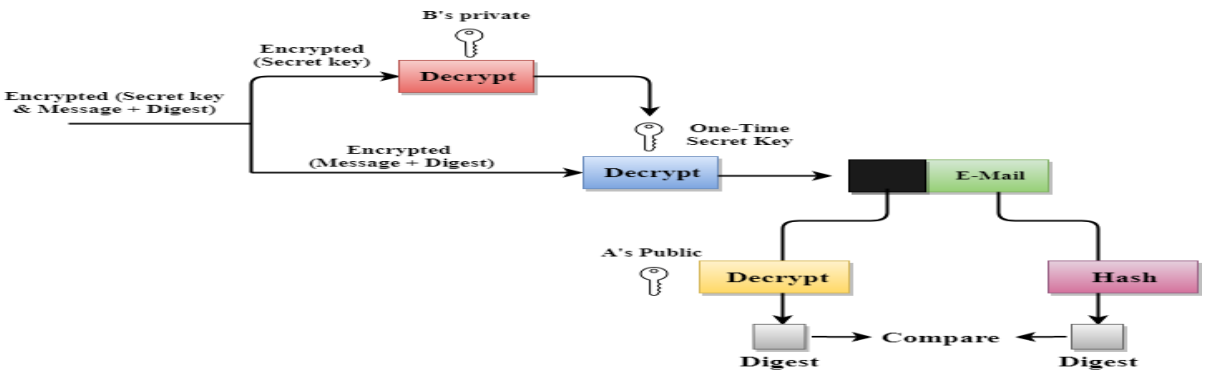
PGP at the Sender site (A)



Following are the steps taken to show how PGP uses hashing and a combination of three keys to generate the original message:

- The receiver receives the combination of encrypted secret key and message digest is received.
- The encrypted secret key is decrypted by using the receiver's private key to get the one-time secret key.
- The secret key is then used to decrypt the combination of message and digest.
- The digest is decrypted by using the sender's public key, and the original message is hashed by using a hash function to create a digest.
- Both the digests are compared if both of them are equal means that all the aspects of security are preserved.

PGP at the Receiver site (B)

- 

Disadvantages of PGP Encryption

- **The Administration is difficult:** The different versions of PGP complicate the administration.
- **Compatibility issues:** Both the sender and the receiver must have compatible versions of PGP. For example, if you encrypt an email by using PGP with one of the encryption technique, the receiver has a different version of PGP which cannot read the data.
- **Complexity:** PGP is a complex technique. Other security schemes use symmetric encryption that uses one key or asymmetric encryption that uses two different keys. PGP uses a hybrid approach that implements symmetric encryption with two keys. PGP is more complex, and it is less familiar than the traditional symmetric or asymmetric methods.
- **No Recovery:** Computer administrators face the problems of losing their passwords. In such situations, an administrator should use a special program to retrieve passwords. For example, a technician has physical access to a PC which can be used to retrieve a password. However, PGP does not offer such a special program for recovery; encryption methods are very strong so, it does not retrieve the forgotten passwords results in lost messages or lost files.

Secure/Multipurpose Internet Mail Extension (S/MIME)

S/MIME is a security-enhanced version of Multipurpose Internet Mail Extension (MIME). In this, public key cryptography is used for digital sign, encrypt or decrypt the email. User acquires a public-private key pair with a trusted authority and then makes appropriate use of those keys with email applications.

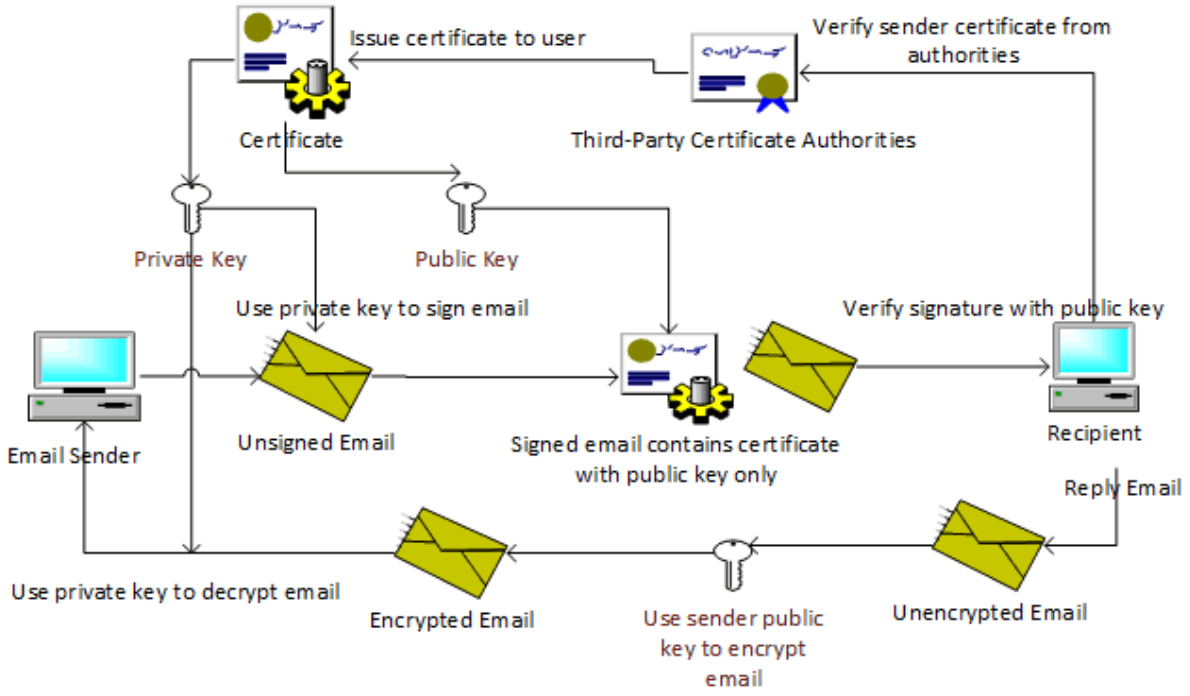
RFC 5322

• Defines a format for text messages that are sent using electronic mail • Messages are viewed as having an envelope and contents – The envelope contains whatever information is needed to accomplish transmission and delivery – The contents compose the object to be delivered to the recipient – RFC 5322 standard applies only to the contents • The content standard includes a set of header fields that may be used by the mail system to create the envelope

A security enhancement to the MIME Internet e-mail format standard based on technology from RSA Data Security.

S/MIME is a protocol for the secure exchange of e-mail and attached documents originally developed by RSA Security. Secure/Multipurpose Internet Mail Extensions (S/MIME) adds security to

Internet e-mail based on the Simple Mail Transfer Protocol (SMTP) method and adds support for digital signatures and encryption to SMTP mail to support authentication of the sender and privacy of the communication. Note that because HTTP messages can transport MIME data, they can also use S/MIME.



How It Works

- .

Nonrepudiation The uniqueness of a signature prevents the owner of the S/MIME is an extension of the widely implemented Multipurpose Internet Mail Extensions (MIME) encoding standard, which defines how the body portion of an SMTP message is structured and formatted. S/MIME uses the RSA public key cryptography algorithm along with the Data Encryption Standard (DES) or Rivest-Shamir-Adleman (RSA) encryption algorithm. In an S/MIME message, the MIME body section consists of a message in PKCS #7 format that contains an encrypted form of the MIME body parts. The MIME content type for the encrypted data is application/pkcs7-mime.

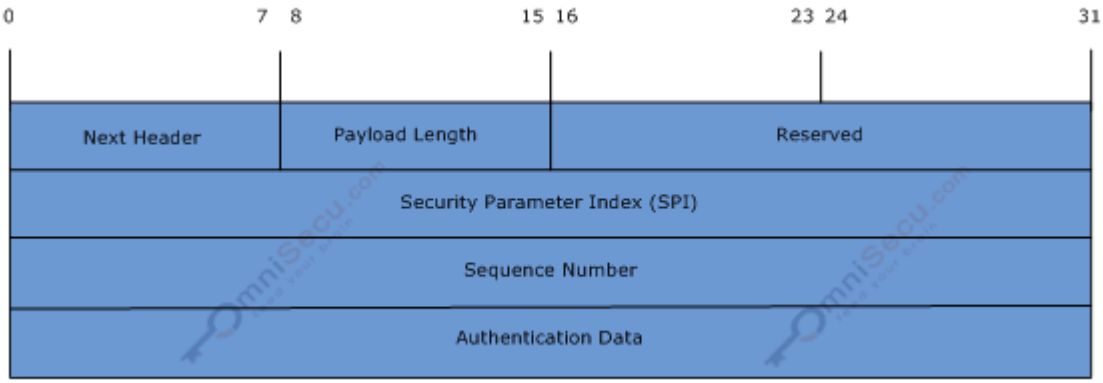
Services of S/MIME:

- **Authentication** A signature serves to validate an identity. It verifies the answer to “who are you” by providing a means of differentiating that entity from all others and proving its uniqueness. Because there is no authentication in SMTP e-mail, there is no way to know who actually sent a message. Authentication in a digital signature solves this problem by allowing a recipient to know that a message was sent by the person or organization who claims to have sent the messagesignature from disowning the

signature. This capability is called nonrepudiation. Thus, the authentication that a signature provides gives the means to enforce nonrepudiation.

- **Data integrity** An additional security service that digital signatures provide is data integrity. Data integrity is a result of the specific operations that make digital signatures possible. With data integrity services, when the recipient of a digitally signed e-mail message validates the digital signature, the recipient is assured that the e-mail message that is received is, in fact, the same message that was signed and sent, and has not been altered while in transit. Any alteration of the message while in transit after it has been signed invalidates the signature.

AUTHENTICATION HEADER



Next Header: Next header field points to next protocol header that follows the AH header. It can be a Encapsulating Security Payload (ESP) header, a TCP header or a UDP header (depending on the network application).

Payload Length: specifies the length of AH in 32-bit words (4-byte units), minus 2.

RESERVED: This field is currently set to 0, reserved for future use.

Security Parameter Index (SPI): The Security Parameter Index (SPI) field contains the Security Parameter Index, is used to identify the security association used to authenticate this packet.

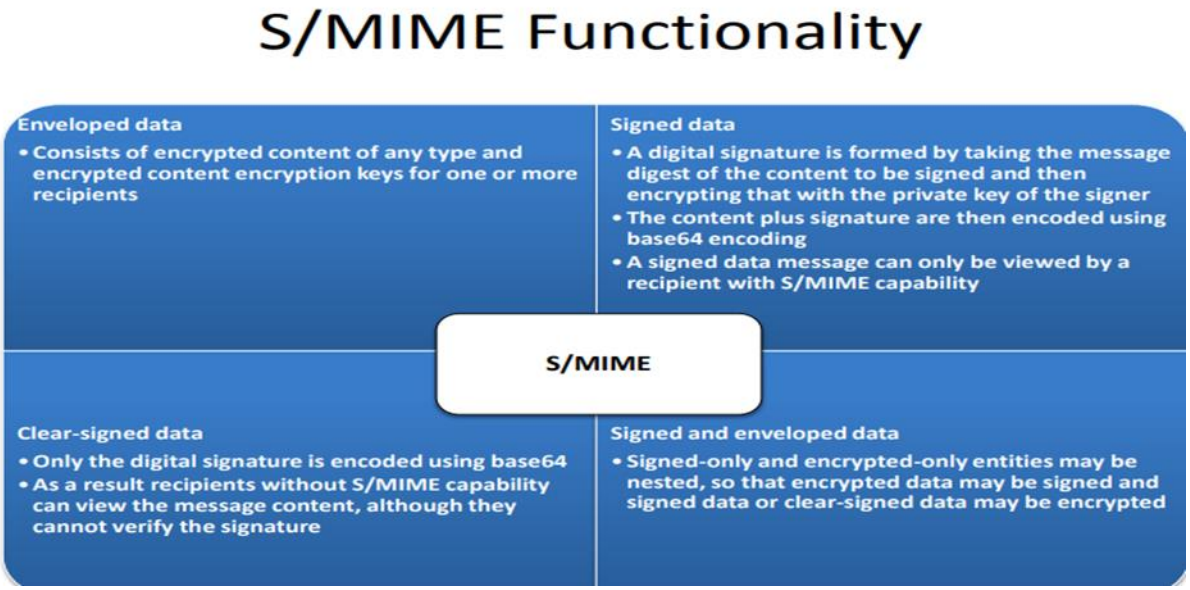
Sequence Number: Sequence Number field is the number of messages sent from the sender to the receiver using the current SA. The initial value of the counter is 1. The function of this field is to enable replay protection, if required.

Authentication Data: The Authentication Data field contains the result of the Integrity Check Value calculation, that can be used by the receiver to check the authentication and integrity of the packet. This field is padded to make total length of the AH is an exact number of 32-bit words. RFC 2402 requires that all AH implementations support at least HMAC-MD5-96 and HMAC-SHA1-96.

- Support for data integrity & authentication of IP packets

- Authentication – MAC code

• Data integrity – undetected modification not possible

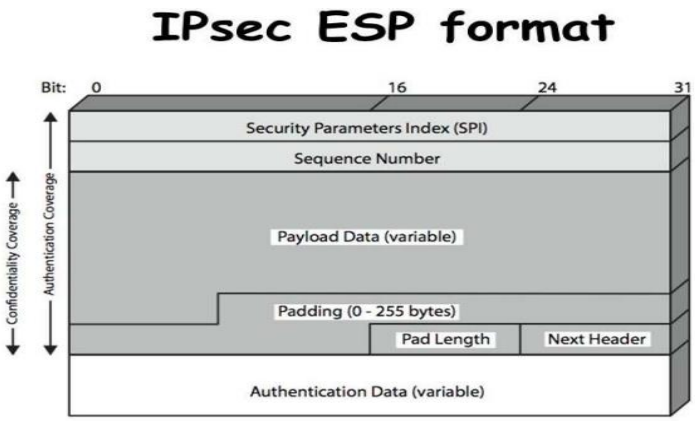


Encapsulating Security payload

provides message content confidentiality, data origin authentication, connectionless integrity, an antireplay service, limited traffic flow confidentiality

• services depend on options selected when establish Security Association (SA), net location

• can use a variety of encryption & authentication algorithms.



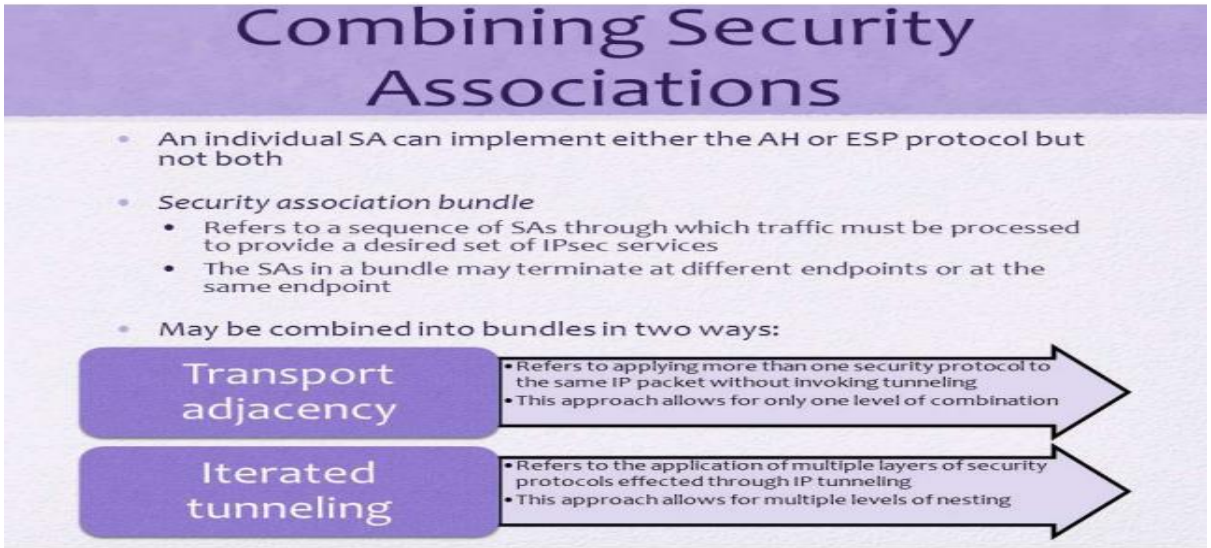
Encryption & Authentication Algorithms & Padding

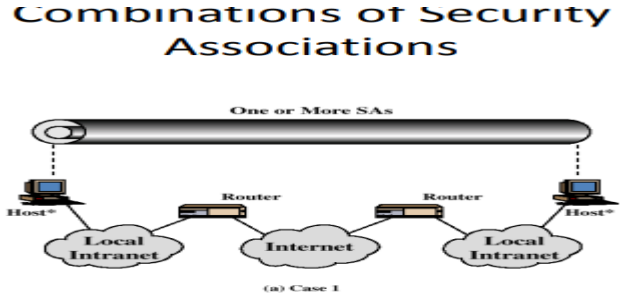
• ESP can encrypt payload data, padding, pad length, and next header fields – if needed have IV at start of payload data

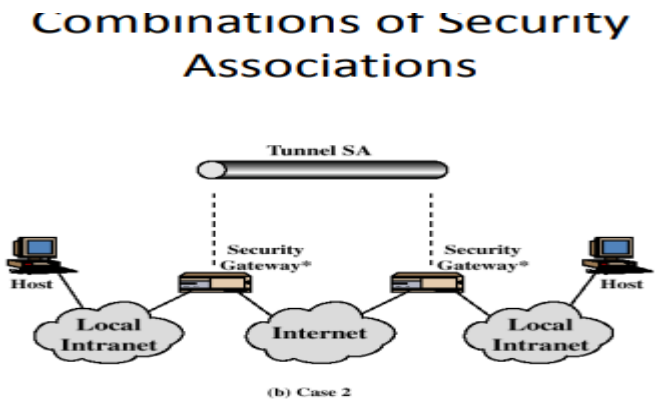
• ESP can have optional ICV (integrity check value) for integrity – is computed after encryption is performed

• ESP uses padding – to expand plaintext to required length – to align pad length and next header fields – to provide partial traffic flow confidentiality.

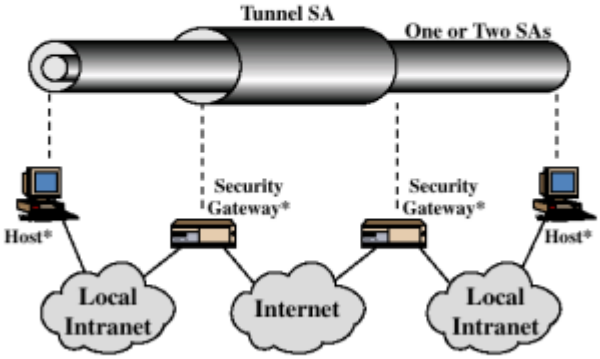
Combining Security associations







Combinations of Security Associations



(c) Case 3

Combining security associations

- **basic ESP-AH combination**
  1. **apply ESP in transport mode without authentication**
  2. **apply AH in transport mode**

original IP header	AH	ESP header	TCP/UDP header	data	ESP trailer

authenticated except for mutable fields in the IP header

- **basic AH-ESP combination**
  1. **apply AH in transport mode**
  2. **apply ESP in tunnel mode without authentication**

new IP header	ESP header	original IP header	AH	TCP/UDP header	data	ESP trailer

authenticated except for mutable fields in the inner IP header

Key management

There are two aspects for Key Management:

1. Distribution of public keys.
2. Use of public-key encryption to distribute secrets.

Distribution of Public Key:

The public key can be distributed in four ways:

3. Public announcement
4. Publicly available directory

5. Public-key authority
6. Public-key certificates.

Public Announcement: Here the public key is broadcasted to everyone. The major weakness of this method is a forgery. Anyone can create a key claiming to be someone else and broadcast it. Until forgery is discovered can masquerade as claimed user.

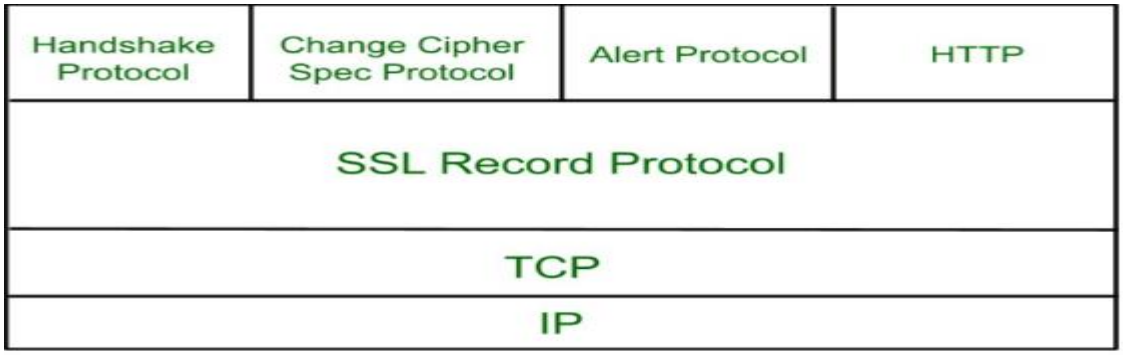
Publicly Available Directory: In this type, the public key is stored in a public directory. Directories are trusted here, with properties like Participant Registration, access and allow to modify values at any time, contains entries like {name, public-key}. Directories can be accessed electronically still vulnerable to forgery or tampering.

Public Key Authority: It is similar to the directory but, improves security by tightening control over the distribution of keys from the directory. It requires users to know the public key for the directory. Whenever the keys are needed, real-time access to the directory is made by the user to obtain any desired public key securely.

Public Certification: This time authority provides a certificate (which binds an identity to the public key) to allow key exchange without real-time access to the public authority each time. The certificate is accompanied by some other info such as period of validity, rights of use, etc. All of this content is signed by the private key of the certificate authority and it can be verified by anyone possessing the authority's public key.

Web Security: SSL and Transport Layer Security

Secure Socket Layer (SSL) provides security to the data that is transferred between web browser and server. SSL encrypts the link between a web server and a browser which ensures that all data passed between them remain private and free from attack.



Secure Socket Layer Protocols:

- SSL record protocol
- Handshake protocol
- Change-cipher spec protocol
- Alert protocol

SSL Record Protocol:

SSL Record provides two services to SSL connection.

- Confidentiality
- Message Integrity

In the SSL Record Protocol application data is divided into fragments. The fragment is compressed and then encrypted MAC (Message Authentication Code) generated by algorithms like SHA (Secure Hash Protocol) and MD5 (Message Digest) is appended. After that encryption of the data is done and in last SSL header is appended to the data.

Handshake Protocol:

Handshake Protocol is used to establish sessions. This protocol allows the client and server to authenticate each other by sending a series of messages to each other. Handshake protocol uses four phases to complete its cycle.

- **Phase-1:** In Phase-1 both Client and Server send hello-packets to each other. In this IP session, cipher suite and protocol version are exchanged for security purposes.
- **Phase-2:** Server sends his certificate and Server-key-exchange. The server end phase-2 by sending the Server-hello-end packet.
- **Phase-3:** In this phase, Client replies to the server by sending his certificate and Client-exchange-key.
- **Phase-4:** In Phase-4 Change-cipher suite occurred and after this Handshake Protocol ends.

Change-cipher Protocol:

This protocol uses the SSL record protocol. Unless Handshake Protocol is completed, the SSL record Output will be in a pending state. After handshake protocol, the Pending state is converted into the current state.
Change-cipher protocol consists of a single message which is 1 byte in length and can have only one value. This protocol's purpose is to cause the pending state to be copied into the current state.

Alert Protocol:

This protocol is used to convey SSL-related alerts to the peer entity. Each message in this protocol contains 2 bytes.

Some types of alerts:

Handshake failure: When the sender is unable to negotiate an acceptable set of security parameters given the options available.
Decompression failure: When the decompression function receives improper input.
Illegal parameters: When a field is out of range or inconsistent with other fields.
Bad record MAC: When an incorrect MAC was received.
Unexpected message: When an inappropriate message is received.

Transport Layer Security

Transport Layer Securities (TLS) are designed to provide security at the transport layer. TLS was derived from a security protocol called Secure Socket Layer (SSL). TLS ensures that no third party may eavesdrop or tampers with any message.
There are several benefits of TLS:

- **Encryption:**
  TLS/SSL can help to secure transmitted data using encryption.
- **Interoperability:**
  TLS/SSL works with most web browsers, including Microsoft Internet Explorer and on most operating systems and web servers.
  - **Algorithm flexibility:**
    TLS/SSL provides operations for authentication mechanism, encryption algorithms and hashing algorithm that are used during the secure session.
  - **Ease of Deployment:**
    Many applications TLS/SSL temporarily on a windows server 2003 operating systems.
  - **Ease of Use:**
    Because we implement TLS/SSL beneath the application layer, most of its operations are completely invisible to client.

Working of TLS:

The server checks what the highest SSL/TLS version is that is supported by them both, picks a cipher suite from one of the clients option (if it supports one) and optionally picks a compression method. After this the basic setup is done, the server provides its certificate. This certificate must be trusted either by the client itself or a party that the client trusts. Having verified the certificate and being certain this server really is who he claims to be (and not a man in the middle), a key is exchanged. This can be a public key.

Both the server and client can now compute the key for symmetric encryption. The handshake is finished and the two hosts can communicate securely.

To close a connection by finishing. TCP connection both sides will know the connection was improperly terminated. The connection cannot be compromised by this through, merely interrupted.

Secure electronic transaction

Secure Electronic Transaction or SET is a system that ensures the security and integrity of electronic transactions done using credit cards in a scenario. SET is not some system that enables payment but it is a security protocol applied to those payments. It uses different encryption and hashing techniques to secure payments over the internet done through credit cards.

SET protocol restricts the revealing of credit card details to merchants thus keeping hackers and thieves at bay. The SET protocol includes Certification Authorities for making use of standard Digital Certificates like X.509 Certificate.

Requirements in SET :
The SET protocol has some requirements to meet, some of the important requirements are :

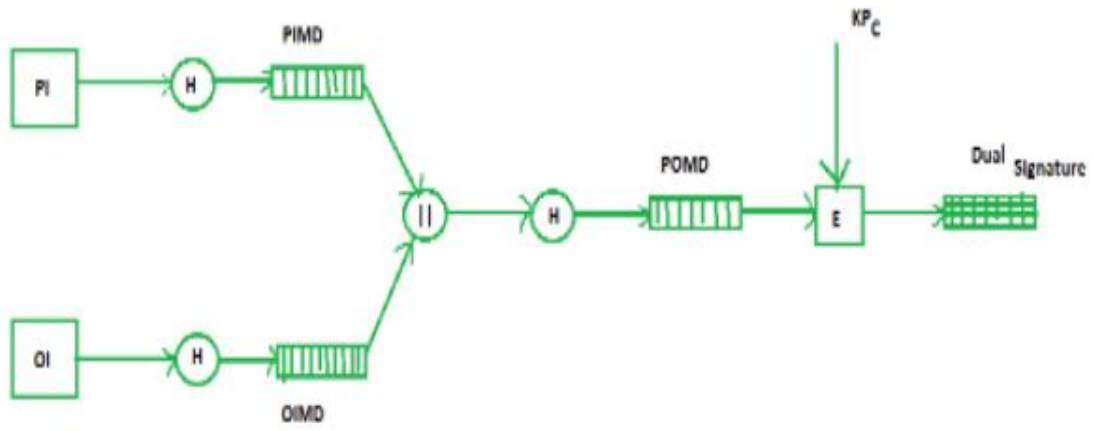
- It has to provide mutual authentication i.e., customer (or cardholder) authentication by confirming if the customer is an intended user or not, and merchant authentication.
- It has to keep the PI (Payment Information) and OI (Order Information) confidential by appropriate encryptions.
- It has to be resistive against message modifications i.e., no changes should be allowed in the content being transmitted.

SET functionalities :

- **Provide Authentication**
    - **Merchant Authentication** – To prevent theft, SET allows customers to check previous relationships between merchants and financial institutions. Standard X.509V3 certificates are used for this verification.
    - **Customer / Cardholder Authentication** – SET checks if the use of a credit card is done by an authorized user or not using X.509V3 certificates.
- **Provide Message Confidentiality**: Confidentiality refers to preventing unintended people from reading the message being transferred. SET implements confidentiality by using encryption techniques. Traditionally DES is used for encryption purposes.

- **Provide Message Integrity**: SET doesn't allow message modification with the help of signatures. Messages are protected against unauthorized modification using RSA digital signatures with SHA-1 and some using HMAC with SHA-1.

Dual Signature :
The dual signature is a concept introduced with SET, which aims at connecting two information pieces meant for two different receivers :
Order Information (OI) for merchant
Payment Information (PI) for bank



PI stands for payment information

OI stands for order information

PIMD stands for Payment Information Message Digest

OIMD stands for Order Information Message Digest

POMD stands for Payment Order Message Digest

H stands for Hashing

E stands for public key encryption

KPc is customer's private key

|| stands for append operation

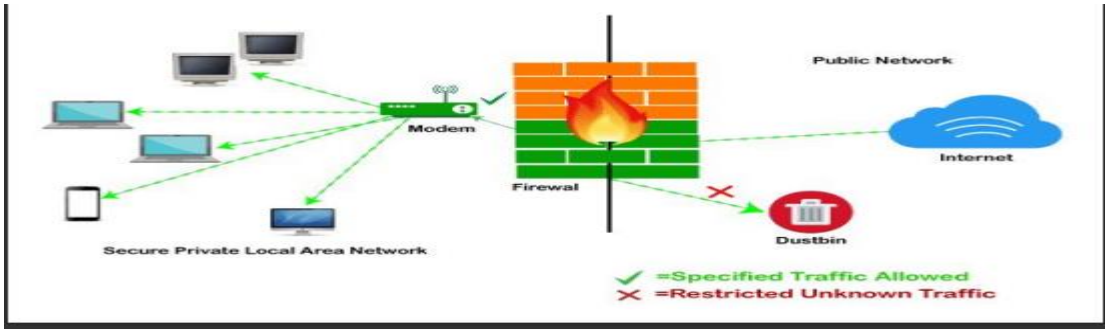
Dual signature, DS= E(KPc, [H(H(PI)||H(OI))])

Firewalls

What is a Firewall?

● A firewall can be defined as a special type of network security device or a software program that monitors and filters incoming and outgoing network traffic based on a defined set of security rules. It acts as a barrier between internal private networks and external sources (such as the public Internet).

● The primary purpose of a firewall is to allow non-threatening traffic and prevent malicious or unwanted data traffic for protecting the computer from viruses and attacks. A firewall is a cybersecurity tool that filters network traffic and helps users block malicious software from accessing the Internet in infected computers.



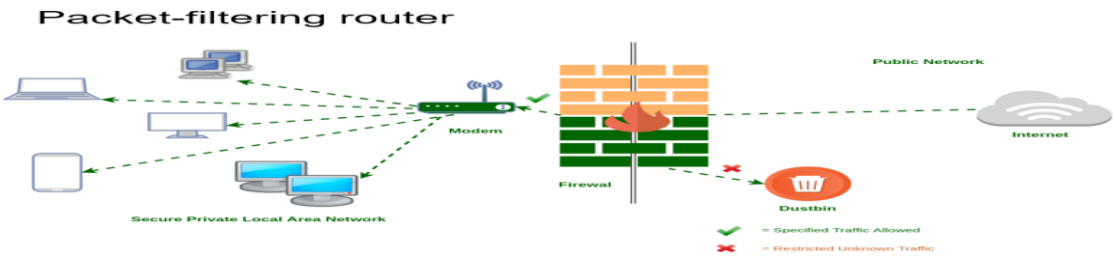
A firewall implemented as hardware or software has different functionality but the same purpose.

A hardware firewall is a physical device that attaches between a computer network and a gateway. For example, a broadband router.

On the other hand, a software firewall is a simple program installed on a computer that works through port numbers and other installed software.

Types of firewall

1. Packet-filtering router
2. Application-level gateway
3. Circuit-level gateway



- It applies a set of rules on each packet and based on the outcome, decides to either forward or discard the packet.
- Packet filter firewall controls access to packets on the basis of packet source and destination address or specific transport protocol type.
- Packet filter firewall works on the network layer of the OSI model.

Application-level gateway(Proxy server)

Proxy firewalls operate at the application layer as an intermediate device to filter incoming traffic between two end systems (e.g., network and traffic systems). That is why these firewalls are called 'Application-level Gateways'.

These firewalls transfer requests from clients pretending to be original clients on the web-server.

This protects the client's identity and other suspicious information, keeping the network safe from potential attacks.

Once the connection is established, the proxy firewall inspects data packets coming from the source.

If the contents of the incoming data packet are protected, the proxy firewall transfers it to the client. This approach creates an additional layer of security between the client and many different sources on the network.

Application-level gateway tend to be more secure than packet filter.

Circuit-Level gateway

A circuit-level gateway does not permit an end to end TCP connection,rather than the gateway set up two TCP connection:

- ❖ One between itself and a TCP user on an inner host.

❖ One between itself and a TCP user on an outside host.

Once the two connections are established,the gateway typically relies TCP sagement from one connection to another without examining the content.

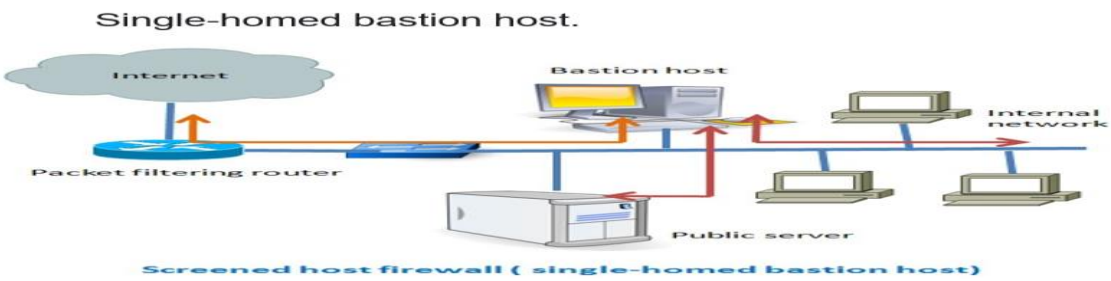
Like packet-filtering firewalls, these firewalls do not check for actual data, although they inspect information about transactions. Therefore, if a data contains malware, but follows the correct TCP connection, it will pass through the gateway. That is why circuit-level gateways are not considered safe enough to protect our systems.

Firewall configuration

What is a bastion host?

A bastion host is **a server whose purpose is to provide access to a private network from an external network**, such as the Internet

1. Single-homed bastion host.
2. Duel-homed bastion host.
3. Screened-subnet firwall system.

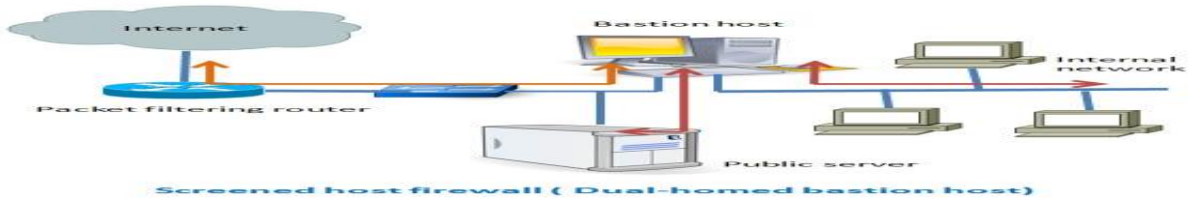


In case of single homed bastion host the firewall system consists of a ***packet filtering router and a bastion host.***

Which has the following characteristics:

- Traffic from the Internet can only reach the bastion host; they cannot reach the internal network.
- Traffic having the IP address of the bastion host can only go to the Internet. No traffic from the internal network can go to the Internet.
- The main problem with the single homed bastion host is that if the packet filter route gets compromised then the entire network will be compromised.

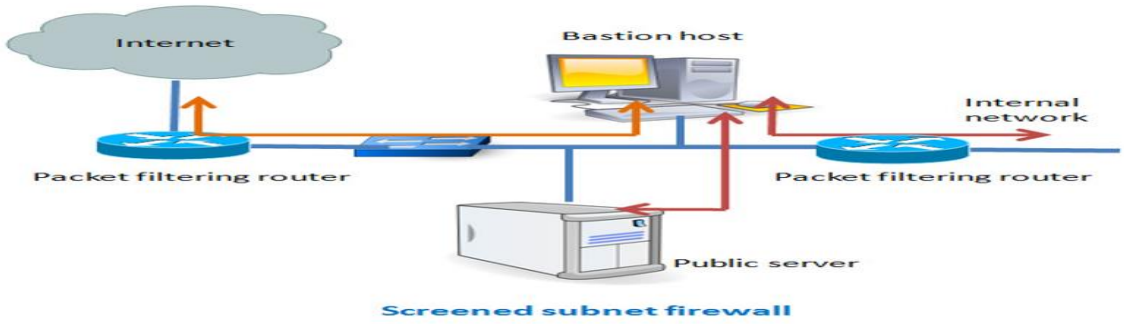
Dual homed bastion host



To eliminate this drawback we can use the **dual homed bastion host** firewall system, where a bastion host has two network cards- one is used for internal connection and the second one is used for connection with the router.

In this case, even if, the router got compromised, the internal network will remain unaffected since it is in the separate network zone.

Screened subnet firewalls



- Two packet-filtering routers are used ,one between the bastion host and the internet and one between the bastion host and the internal network.
- This configuration creates an isolated subnetwork.

Trusted Systems

Trusted Systems are special systems designed to serve the purpose of providing security. Safety is ensured by trusted system in a manner by protecting the system against malicious softwares and third party intruders. Trusted system allow only verified users to access the computer system. Trusted system are responsible for providing security at different levels and based on different parameters.

Trusted Systems are based on different level of security. They are mentioned as below:

- **Multilevel Security:** This type of Trusted system ensures that security is maintained at different levels of the computer system. It ensures that the information is prevented from being at risk. The different security levels of computer systems are :

    - Top Secret Level
    - Secret Level
    - Confidential Level
    - Unclassified Level
- The order of security level is also given by top level security having the highest priority followed by secret Level priority, confidential Level priority and then least priority is assigned to unclassified level priority. If security is not cleared at one particular level, flow of information is restricted.

- **Data Access Control:** This type of Trusted system provides additional security to the verified process of log-in. It helps in setting permissions for different users, giving them limited access and restricting any additional accesses granted. There are three basic models of Data Access Control:
    - **Access Matrix:** They are composed of three parts
        - Subject
        - Object
        - Access right
    - **Access Control List:** They are composed of different entries of objects depicting user access and the level of access granted (public or private). Access control list demonstrate column-wise split.
    - **Capability List:** They are composed of authorised users and the granted operations for them. Users can have multiple capability tickets. Capability list demonstrate row-wise split.
- **Reference Monitor:** This type of trusted system provides hardware level security by limiting the access to objects. Reference monitor maintain security rules ensuring that 'Read Up' and 'Write Down' operations are not performed. Reference monitor ensure that the entire security maintaining process that is carried out is verified and safe.

Importance of Trusted System:
- **Identity Verification:** Trusted systems ensure that only verified users are given access. The verification process takes place that each user is identified uniquely.
- **Safety Maintained:** Trusted system ensures that safety is maintained by preventing direct access to confidential information.
- **Limiting Access:** Permissions and access that are absolutely necessary are granted for users. Unwanted rules and permissions are avoided.

INTRUDERS

- Intruders are the important and serious thread to security which are commonly known as hackers or cracker.
- Intruders are the person who access the network illegally and try to damage the privacy.
- Intruders is any unauthorized access(illegally access the system without knowing the users) to the system.

Types of Intruders

1) Masquerader: An individual who is not authorized to use the computer and who penetrates a system's access control to exploit a legitimate user's account.
2) Misfeasor: A legitimate who accesses data, programs, or resources for which such access is not authorized, or who is authorized for such accesses but misuses his or her previlege.

3) Clandestine user: An individual who grabs supervisory control of the system and uses this control to evade auditing and access controls or to suppress audit collection.

Need for intrusion Monitoring and Detection

- Protected information assets are not accessed by unauthorized entities.
- Ability to monitor network traffic without impact to the network.
- Actively respond to attacks on systems.
- Security professionals are able to understand the attacks on the networks and building systems to resist those attacks.
- Security metrics get generated.

Intrusion Techniques

❖ **Password Guessing:**

✓ One of the most common attacks is password guessing

✓ Attacker known a login (from of email/web page etc.)

✓ Then attempt to guess password for it.

✓ Check by login or against stolen password file

✓ Success depend on password chosen by user

❖ **Password Capture**

✓ Another attack involves password capture

✓ Watching over shoulder as password is entered

✓ Monitoring an insecure network login

✓ Extracting recorded info after successful login

Intrusion Detection System(IDS)

- Intrusion detection is the act of detecting actions that attempt to compromise the confidentiality, integrity or availability of a resource. When intrusion detection takes a preventive measure without direct human intervention, then it becomes an intrusion prevention system.
- Intrusion detection is based on the assumption that the behavior of the intruder differs from that of a legitimate user in ways that can be quantified.

Approaches to Intrusion Detection

- Statistical anomaly detection: Collect data relating to the behavior of legitimate users, then use statistical test to determine with a high level of confidence whether new behavior is legitimate user behavior or not.
- Threshold(entry) – define thresholds, independent of user, for the frequency of occurrence of events.
- Profile based – develop profile of activity of each user and to detect changes in the behavior.
- Rule based detection: Attempt to define a set of rules used to decide if given behavior is an intruders.
- Anomaly(abnormal) – rules detect deviation from previous usage patterns
- Penetration(entry – action) – identification-expert system approach that searches for suspicious behavior(doubt).

Malicious software

Malware is a software that gets into the system without user consent with an intention to steal private and confidential data of the user that includes bank details and password. They also generates annoying pop up ads and makes changes in system settings

They get into the system through various means:

1. Along with free downloads.
2. Clicking on suspicious link.
3. Opening mails from malicious source.
4. Visiting malicious websites.
5. Not installing an updated version of antivirus in the system.

Types:
1. Virus
2. Worm
3. Logic Bomb
4. Trojan/Backdoor
5. Rootkit
6. Advanced Persistent Threat
7. Spyware and Adware

computer virus:
Computer virus refers to a program which damages computer systems and/or destroys or erases data files. A computer virus is a malicious program that self-replicates by copying itself to another program. In other words, the computer virus spreads by itself into other executable code or documents. The purpose of creating a computer virus is to infect vulnerable systems, gain admin control and steal user sensitive data.

Symptoms:
- Letter looks like they are falling to the bottom of the screen.
- The computer system becomes slow.
- The size of available free memory reduces.
- The hard disk runs out of space.
- The computer does not boot.

Worm:
A worm is a destructive program that fills a computer system with self-replicating information, clogging the system so that its operations are slowed down or stopped.
Types of Worm:
1. **Email worm –** Attaching to fake email messages.
2. **Instant messaging worm –** Via instant messaging applications using loopholes in network.
3. **Internet worm –** Scans systems using OS services.
4. **Internet Relay Chat (IRC) worm –** Transfers infected files to web sites.

Logical Bomb:
A logical bomb is a destructive program that performs an activity when a certain action has occurred. These are hidden in programming code. Executes only when a specific condition is met, e.g. Jerusalem.

Script Virus:
Commonly found script viruses are written using the Visual Basic Scripting Edition (VBS) and the JavaScript programming language.

Trojan / Backdoor:
Trojan Horse is a destructive program. It usually pretends as computer games or application software. If executed, the computer system will be damaged. Trojan Horse

usually comes with monitoring tools and key loggers. These are active only when specific events are alive.

Advanced Persistent Threat:
Created by well funded, organized groups, nation-state actors, etc. Desire to compromise government and commercial entities, e.g. Flame: used for reconnaissance and information gathering of system.
Spyware and Adware:
Normally gets installed along with free software downloads. Spies on the end-user, attempts to redirect the user to specific sites. Main tasks: Behavioral surveillance and advertising with pop up ads Slows down the system.

RootKits:
Collection of tools that allow an attacker to take control of a system.

- Can be used to hide evidence of an attacker's presence and give them backdoor access.
- Can contain log cleaners to remove traces of attacker.
  - Gains control of infected m/c by:
    – DLL injection: by injecting malicious DLL (dynamic link library)
    – Direct kernel object manipulation: modify kernel structures and directly target trusted part of OS
    – Hooking: changing applicant's execution flow